

Enterprise Security & Compliance Overview

Zero-Retention Architecture | SOC2-Aligned | HIPAA-Ready

0s

Data Retention

TLS 1.2+

Encryption

SOC2

Aligned

HIPAA

Ready

CONFIDENTIAL — For authorized enterprise review only

DocChat AI | docchat-saas.vercel.app | support.docchatai@proton.me

Version 1.0 | May 2026

1. Enterprise Security Overview

DocChat AI is designed as a stateless, zero-retention document processing platform. Customer data is processed exclusively in-memory during active sessions and is never written to persistent storage.

This architecture eliminates entire classes of data security risk, including data-at-rest breaches, backup exposure, and unauthorized historical access.

Core Security Principles

- Zero Data Retention — Customer documents and extracted content are not stored under any circumstances.
- Ephemeral Processing — All data exists only in volatile memory during an active session.
- No Content Logging — Document content, prompts, and outputs are never logged.
- Minimal Data Exposure — Only the minimum necessary text is transmitted for inference.
- No Training Usage — Customer data is never used for model training.

2. Zero-Retention Architecture

Data Lifecycle

All customer data follows a strictly ephemeral lifecycle:

- Document uploaded via encrypted connection (TLS 1.2+)
- Data loaded into memory (RAM only) — never written to disk
- Processing performed in-session, isolated per user
- Response returned to user
- Session terminates — memory is cleared automatically

At no point is data written to: disk, databases, object storage, or logs.

Security Implications

- No historical data exists to be breached
- No internal access to prior documents is possible
- No backups contain customer data
- No data recovery is possible after session termination

3. Encryption & Key Management

Property	Implementation
Encryption in Transit	TLS 1.2+ (ECDHE, AES-256-GCM) — Perfect Forward Secrecy enabled
Encryption at Rest	Not applicable — no customer data is stored
Key Management	Session-level ephemeral keys via TLS handshake; no persistent key storage

4. Identity & Access Management

Customer Authentication

- Single Sign-On (SSO): Google, Microsoft Entra ID (Business Plan)

- Multi-Factor Authentication (MFA) supported via SSO provider

Internal Access Controls

- Role-Based Access Control (RBAC) enforced for all internal systems
- Multi-Factor Authentication (MFA) required for all administrative access
- Least privilege model applied across all roles
- No internal access to customer documents is possible — zero-retention by design

5. Data Handling & Privacy	
Category	DocChat AI Policy
Document storage	Never stored. Session-only, ephemeral RAM.
Text extraction	In-memory only. Not retained.
Outputs / responses	Not persisted after session.
Logs	Operational metadata only: timestamps, token counts, error codes.
Document content in logs	Never logged. Strictly excluded.
Training data usage	Never. Customer data is never used for model training.

6. Compliance & Regulatory Position

SOC2 Alignment

DocChat AI implements controls aligned with SOC2 Type II Trust Services Criteria:

- Security — Protection against unauthorized access
- Availability — System availability for operation and use
- Confidentiality — Information designated as confidential is protected

Formal certification documentation available upon completion of audit. Architecture review package available on request.

HIPAA Readiness

- Business Plan customers can process PHI under HIPAA-ready configuration
- Business Associate Agreements (BAAs) available for healthcare organizations
- No PHI retained after session end
- All API communications TLS-encrypted

7. Subprocessors	
Subprocessor	NVIDIA NIM API
Purpose	Real-time document inference only
Data shared	Minimal text fragments required for processing
Persistence	No storage within DocChat AI systems
Training usage	No customer data used for model training

DocChat AI does not share customer data with any other third parties.

8. Incident Response

DocChat AI maintains a defined incident response process with the following commitments:

- Detection and classification of security incidents
- Containment and investigation procedures
- Enterprise customers notified within 48 hours of confirmed security incidents
- Remediation and post-incident review

Architectural advantage: Due to zero-retention design, incident impact is inherently limited to in-transit exposure scenarios. No stored data can be exfiltrated.

9. Security Assertions

DocChat AI enforces the following guarantees through system architecture, not policy alone:

- Customer data is never stored
- Customer data is never logged
- Customer data is never used for training
- Customer data cannot be accessed after session termination
- No internal or external party can retrieve past documents

10. Contact Enterprise Security

For security reviews, documentation requests, BAA execution, or compliance inquiries:

- Email: support.docchatai@proton.me
- Website: <https://docchat-saas.vercel.app/contact>
- Security page: <https://docchat-saas.vercel.app/security>